

Understanding SOC Reports and the AICPA

| What is the AICPA?

The **American Institute of Certified Public Accountants (AICPA)** is the premier national professional organization for Certified Public Accountants in the United States, founded in 1887. With over 400,000 members, it sets the rules, ethics, and standards for the accounting and auditing industry.

The AICPA is the body that defines the framework for SOC (System and Organization Controls) audits. Official SOC reports must be conducted by independent CPA firms following these specific AICPA standards.

| Overview of SOC Audits

SOC reports are independent audits that provide assurance to clients that a service organization manages data securely, accurately, and ethically. They are the industry standard for demonstrating trust.

SOC 1 vs. SOC 2: Key Differences

Feature	SOC 1	SOC 2
Primary Focus	Financial controls and reporting.	Security, availability, and data privacy.
Target Audience	Payroll, billing, loan servicers.	SaaS, cloud hosts, IT providers.
Standard	SSAE 18.	Trust Services Criteria (TSC).

Type I vs. Type II

- **Type I:** A "point-in-time" assessment of system design.
- **Type II:** A "period-of-time" assessment (usually 6–12 months) verifying that controls operate effectively over time.

| The SOC 2 Trust Services Criteria

SOC 2 audits are structured around these pillars:

- **Security (Common Criteria):** Protecting systems against unauthorized access.
- **Availability:** Ensuring systems are operational as promised.
- **Processing Integrity:** Ensuring data processing is accurate and timely.
- **Confidentiality:** Restricting access to sensitive data.
- **Privacy:** Protecting personal information.

| What is a SOC 3 Report?

A **SOC 3 report** is the public-facing version of a SOC 2. It is a high-level summary meant for marketing and public trust, lacking the sensitive technical details found in a full SOC 2 report.

While SOC 2 is restricted and detailed (50–100+ pages), SOC 3 is public and brief (5–10 pages). You do not perform a separate audit for SOC 3; it is simply a differently packaged version of the SOC 2 results.